MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D07

MDM Security Standard

Deliverable 7 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

MDM Security Standard

MDM-D07

1. Purpose and Applicability

This standard defines verifiable technical requirements supporting MDM-D05 controls and the MDM-D06 policy. Requirements and platform mappings do not demonstrate implementation or effectiveness. Conditional Access design is addressed in MDM-D08, evidence collection in MDM-D09, and control testing in MDM-D10.

2. Management Models and Prerequisites

Company-owned mobile devices must be assigned to individual users and used for business purposes only. The following management models are selected for the service design:

Device Group	Selected Management Model
Company-owned Android	Android Enterprise Fully Managed, associated with a single user.
Company-owned iOS/iPadOS	Automated Device Enrollment (ADE), supervised, with user affinity.
Employee BYOD - Android and iOS/iPadOS	Intune App Protection without MDM enrollment.

Enrollment prerequisites, licensing, supported platforms and configuration dependencies must be validated before implementation. Contractors must use company-issued devices.

2.1 Technical Prerequisites

Area	Required Prerequisites
Identity and Licensing	In-scope users must have individual corporate Microsoft Entra accounts, Intune Plan 1 user entitlements or equivalent included rights, and Microsoft Entra ID P1 or higher for Conditional Access. Required Microsoft 365 service entitlements must also be verified.
Corporate Android	Devices must support Android Enterprise Fully Managed and Google Mobile Services. Intune must be connected to Managed Google Play. Devices must be new or factory-reset for provisioning, with an assigned fully managed enrollment profile.
Corporate iOS/iPadOS	Devices must be available in the corporate Apple automated enrollment service and assigned to

Area	Required Prerequisites
	Intune. An active ADE token and Apple MDM push certificate are required. New or erased devices must receive an ADE profile with supervision and user affinity.
BYOD Applications and Identity	Approved applications must support Intune App Protection. Policies must target the relevant users and applications. Required authentication brokers and Microsoft Entra device registration must be validated without introducing MDM enrollment.
Dependency Maintenance	IT Operations must track certificate and token expiry, renewal responsibilities and service connectivity. Supported OS and application versions must be verified against the technical requirements defined in this standard.

These prerequisites are defined requirements, not confirmed implementation. License assignments, service connections, enrollment settings and application dependencies remain subject to evidence review and testing.

3. Corporate Device Security

3.1 Device Passcode and Automatic Lock - Android

Requirement ID: MDM-STD-001

Field	Details
Scope and traceability	MDM-AST-001, company-owned Android (Fully Managed). Supports MDM-CTL-001 and MDM-D06 Section 5.
Requirement	A PIN of at least six digits; repeated or sequential PINs blocked; automatic lock within five minutes of inactivity; immediate authentication after lock, with no grace period.
Verification	Short, repeated and sequential PINs are rejected. The device locks within five minutes. Authentication is required straight after automatic and manual lock.
Constraints and status	No supported setting is confirmed yet for immediate authentication after lock; IT Operations confirms one for the selected models before activation. Screen-off timing alone does not prove it. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.

Field	Details
Source	Microsoft Learn: Intune Android Enterprise device restrictions, fully managed (device password, power settings). Reviewed 29 October 2026.

3.2 Device Passcode and Automatic Lock — iOS/iPadOS

Requirement ID: MDM-STD-002

Field	Details
Scope and traceability	MDM-AST-004, company-owned iOS/iPadOS (ADE, supervised, user affinity). Supports MDM-CTL-001 and MDM-D06 Section 5.
Requirement	A PIN of at least six digits or a password of at least six characters; simple passcodes blocked; automatic lock within five minutes of inactivity; immediate authentication after lock.
Verification	Short and simple passcodes are rejected and permitted ones accepted. The device locks within five minutes. Authentication is required straight after automatic and manual lock.
Constraints and status	The grace period must stay at zero. The Numeric passcode type does not restrict passcodes to digits only. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Apple device restriction settings in Intune (Password). Reviewed 29 October 2026.

3.3 Operating System and Security Update Baseline

Requirement ID: MDM-STD-003

Field	Details
Scope and traceability	MDM-AST-001 and MDM-AST-004, company-owned Android and iOS/iPadOS. Supports MDM-CTL-003 and MDM-D06 Section 5. Threshold changes follow MDM-CTL-004.
Requirement	Devices meet the approved minimum OS and security update level, and selected models stay supported for updates, Intune management and approved apps. IT Operations reviews thresholds monthly and after relevant

Field	Details
	advisories, and records values, sources and effective dates. A new threshold takes effect on a recorded enforcement date, normally 14 days after approval; critical or actively exploited issues trigger an urgent review with a deadline and interim protections.
Verification	Threshold records show the review date, approved values and enforcement date. Devices below the threshold on that date are reported noncompliant under Section 3.6.
Constraints and status	Platform thresholds are set in Sections 3.4 and 3.5. Device and app compatibility, update availability and build-level thresholds still need validation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: device compliance settings for Android Enterprise and for iOS/iPadOS. Reviewed 29 October 2026.

3.4 Android OS and Security Update Requirements

Requirement ID: MDM-STD-004

Field	Details
Scope and traceability	MDM-AST-001, company-owned Android (Fully Managed). Supports MDM-CTL-003, MDM-STD-003 and MDM-D06 Section 5.
Requirement	Minimum OS version Android 15.0 and minimum security patch level 2026-10-01 (Android Security Bulletin, 5 October 2026). Selected models must have active manufacturer support with monthly security updates.
Verification	Devices below either threshold are reported noncompliant and reassessed after updating. Access enforcement is tested in MDM-D10.
Constraints and status	Both values are project-defined and the patch date does not advance automatically. Manufacturer delivery may lag the bulletin, so availability is confirmed per model before the enforcement date. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android Enterprise compliance settings; Android Security Bulletin, October 2026. Reviewed 29

Field	Details
	October 2026.

3.5 iOS/iPadOS OS and Security Update Requirements

Requirement ID: MDM-STD-005

Field	Details
Scope and traceability	MDM-AST-004, company-owned iOS/iPadOS (ADE, supervised, user affinity). Supports MDM-CTL-003, MDM-STD-003 and MDM-D06 Section 5.
Requirement	Minimum OS version iOS 27.2 and iPadOS 27.2 (released 26 October 2026). Selected models must support iOS/iPadOS 27 and stay eligible for Apple security updates. Where a fix is identified by build rather than version, a minimum build is set.
Verification	Devices below the threshold are reported noncompliant and reassessed after updating. Access enforcement is tested in MDM-D10.
Constraints and status	Devices on iOS/iPadOS 26 do not meet the baseline, even on its latest security release, because one minimum version cannot accept the latest release of two major versions without also accepting unpatched releases of the newer one. Eligible devices must upgrade before the enforcement date. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: iOS/iPadOS compliance settings; Apple: Apple security releases and Security content of iOS 27.2 and iPadOS 27.2. Reviewed 2 November 2026.

3.6 Compliance Assignment and Noncompliance Handling

Requirement ID: MDM-STD-006

Field	Details
Scope and traceability	Company-owned Android and iOS/iPadOS devices. Supports MDM-CTL-003 and MDM-D06 Section 4. Changes follow MDM-CTL-004.
Requirement	Every in-scope device receives its platform compliance policy; enrollment alone never counts as compliance.

Field	Details
	Devices with no policy are marked noncompliant. A failed requirement makes the device noncompliant immediately, with no grace period. A device that has not reported for 7 days is treated as noncompliant. Missing or unverified compliance is never accepted as proof for access.
Verification	Test four cases: no assigned policy, a failed requirement, awaiting evaluation, and no report for more than 7 days. Confirm reassessment after reporting resumes and the resulting access decision.
Constraints and status	Removing the grace period does not mean instant detection or ending open sessions; reporting delays still apply (session limits are in MDM-D08). The 7-day period is project-defined and tenant-wide, so its wider impact is assessed first. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: device compliance policies in Intune; actions for noncompliance; policy refresh intervals. Reviewed 29 October 2026.

3.7 Corporate Device Integrity

Requirement ID: MDM-STD-007

Field	Details
Scope and traceability	MDM-AST-001 and MDM-AST-004, company-owned enrolled devices only. Supports MDM-CTL-003 and MDM-D06 Section 5.
Requirement	Corporate devices pass the platform integrity checks: Android basic and device integrity, and jailbreak detection on iOS/iPadOS. A detected failure makes the device noncompliant under Section 3.6.
Verification	Confirm policy assignment, successful evaluation on approved devices, handling of a detected failure, and reassessment after remediation.
Constraints and status	Integrity checks do not detect every compromise. Android evaluation depends on Google Mobile Services. A missing or failed evaluation is never treated as proof of integrity. Implementation and effectiveness are assessed in MDM-D09

Field	Details
	and MDM-D10.
Source	Microsoft Learn: Android Enterprise and iOS/iPadOS compliance settings; Google: Play Integrity verdicts. Reviewed 29 October 2026.

3.8 Corporate Device Encryption at Rest

Requirement ID: MDM-STD-008

Field	Details
Scope and traceability	MDM-AST-001 and MDM-AST-004, company-owned enrolled devices only. Supports MDM-D06 Section 5 (encryption), MDM-CTL-003 (compliance-based access) and MDM-CTL-001 (passcode).
Requirement	Corporate data on corporate devices is protected by platform-native encryption backed by the passcode in Sections 3.1 and 3.2. Encryption is part of the compliance evaluation.
Verification	MDM-D09 collects policy settings and device-level protection evidence. MDM-D10 tests evaluation and access handling where technically possible and records test limits.
Constraints and status	A configured policy does not prove encryption on a specific device. This requirement does not cover removable media, cloud copies or data in transit. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android Enterprise and iOS/iPadOS compliance settings. Reviewed 29 October 2026.

4. BYOD Application Protection

4.1 Approved Work Applications

Requirement ID: MDM-STD-009

Field	Details
Scope and traceability	MDM-AST-005 and MDM-AST-006, employee BYOD with Intune App Protection and no MDM enrollment. Supports MDM-CTL-002 and MDM-D06 Sections 4 and 5.
Requirement	Six approved work apps: Microsoft Outlook, Teams,

Field	Details
	OneDrive, Word, Excel and PowerPoint, on Android and iOS/iPadOS. All six are covered by the App Protection policies and used only with corporate accounts. Approval of an app does not permit moving corporate data to personal accounts. Mobile browser access stays prohibited under MDM-D06.
Verification	Confirm each approved app is targeted on both platforms and protected as expected. Confirm that unapproved apps cannot reach corporate services.
Constraints and status	Listing an app in a protection policy does not by itself limit access to the approved list; access enforcement is in MDM-D08. Licensing and supported app and OS versions need validation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Supported Microsoft Intune apps. Reviewed 30 October 2026.

4.2 Approved Corporate Storage Destinations

Requirement ID: MDM-STD-010

Field	Details
Scope and traceability	Corporate data in approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Corporate data may be saved only to the company's OneDrive for Business and SharePoint Online, using corporate accounts. Saving or exporting to personal accounts, unapproved storage, local storage or the photo library is blocked.
Verification	Saves to corporate storage succeed. Saves to personal accounts, local storage, the photo library and unapproved services are blocked on both platforms.
Constraints and status	Choosing a storage service does not by itself restrict saves to the company's tenant; account restrictions need validation. Protected app storage and offline caches are not exports, but stay subject to encryption and data removal. Implementation and effectiveness are assessed in MDM-D09

Field	Details
	and MDM-D10.
Source	Microsoft Learn: Troubleshoot data transfer and Intune app protection policies. Reviewed 30 October 2026.

4.3 Corporate Data Copy and Paste Restrictions

Requirement ID: MDM-STD-011

Field	Details
Scope and traceability	Corporate data in approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Copy and paste is allowed between protected corporate apps, and pasting into them from personal apps is allowed. Copying corporate data out to personal or unprotected apps is blocked, with no character-count exception.
Verification	Test three paths on both platforms: corporate Outlook to corporate Word (allowed), corporate Word to a personal notes app (blocked), and a personal notes app to corporate Word (allowed). Also test pasting into personal accounts inside approved apps.
Constraints and status	Protected apps are not automatically limited to the six approved apps, so the effective boundary needs validation. Pasted-in content is not checked for safety. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Troubleshoot restricting cut, copy and paste between applications. Reviewed 30 October 2026.

4.4 Corporate File Transfer Between Applications

Requirement ID: MDM-STD-012

Field	Details
Scope and traceability	Corporate files in approved work apps on MDM-AST-005 and MDM-AST-006, which are not enrolled in MDM by design. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Corporate files stay within approved apps, corporate accounts and approved storage. Sending them to personal or unapproved apps is restricted. No custom exemption

Field	Details
	allows transfer to unapproved apps, and built-in exemptions are reviewed and documented before use.
Verification	Test approved app-to-app transfers and attempts to share with personal apps and accounts. On iOS/iPadOS, record whether the transfer happens and whether the receiving app can read the file.
Constraints and status	Partial. On unenrolled iOS/iPadOS devices, the Share extension can move encrypted corporate files outside managed apps, and App Protection cannot block this path. Encryption does not prove the transfer was prevented. This limitation must be resolved against MDM-D06 before design closure. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: App protection policies overview; data protection framework; data transfer policy exceptions. Reviewed 30 October 2026.

4.5 BYOD Corporate Data Encryption at Rest

Requirement ID: MDM-STD-013

Field	Details
Scope and traceability	Corporate data stored by approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 5 (encryption) and the app protection boundary of MDM-CTL-002.
Requirement	Corporate data stored in approved BYOD apps is encrypted. On Android, App Protection encrypts app data. On iOS/iPadOS, protection relies on device encryption while locked, so a device passcode may be required before app access.
Verification	MDM-D09 collects effective settings and app diagnostics. MDM-D10 tests app access with and without a device passcode on iOS/iPadOS, and protection of stored corporate files, recording any limits on direct verification.
Constraints and status	The app PIN is separate from the device passcode. This requirement does not cover the whole device, personal data or data in transit. Encryption does not show that a transfer

Field	Details
	was prevented (Section 4.4). Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings. Reviewed 30 October 2026.

4.6 BYOD Application Access Protection

Requirement ID: MDM-STD-014

Field	Details
Scope and traceability	Corporate contexts in approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and the app protection boundary of MDM-CTL-002.
Requirement	An app PIN of at least six digits, with simple PINs blocked. Supported biometrics may replace the PIN, but the PIN is required again after 30 minutes. Access requirements are rechecked after 5 minutes of inactivity.
Verification	Short and simple PINs are rejected. Biometric access works, the PIN is required after the timeout and after biometric changes, and the 5-minute recheck applies when switching between protected apps.
Constraints and status	PIN length and timeouts are project-defined. The app PIN is separate from the device lock and from MFA at sign-in, and does not make the device compliant. Behavior varies by platform and app. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; app protection policy logs. Reviewed 30 October 2026.

4.7 BYOD Root and Jailbreak Detection

Requirement ID: MDM-STD-015

Field	Details
Scope and traceability	Approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and the app protection boundary of MDM-CTL-002.
Requirement	Access to corporate data in protected apps is blocked when

Field	Details
	a rooted or jailbroken device is detected.
Verification	Confirm the setting on both platforms and test blocking on a controlled test device where feasible. Configuration evidence alone does not prove effectiveness.
Constraints and status	The block applies inside protected apps only; it does not lock or wipe the personal device. Passing the check does not prove the device is uncompromised. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android app protection policy settings; data protection framework. Reviewed 30 October 2026.

4.8 BYOD Minimum Operating System Requirements

Requirement ID: MDM-STD-016

Field	Details
Scope and traceability	Approved work apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and MDM-CTL-002. Threshold changes follow MDM-CTL-004.
Requirement	Corporate app access requires Android 15.0 or later, or iOS/iPadOS 27.2 or later; devices below are blocked. Before enforcement, IT Operations validates compatibility, informs users and records the effective date. Thresholds are reviewed monthly and after relevant advisories.
Verification	Access is blocked below the threshold and allowed at it on each platform, and is reassessed after updating. Meeting the threshold does not bypass other requirements.
Constraints and status	Initial thresholds are project-defined and match Sections 3.4 and 3.5. Meeting the minimum OS does not establish device compliance; Android patch level is covered in Section 4.9. Devices that cannot meet the baseline are not eligible for BYOD. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; managing OS versions with Intune. Reviewed 30 October 2026.

4.9 BYOD Android Security Patch Requirements

Requirement ID: MDM-STD-017

Field	Details
Scope and traceability	Approved work apps on MDM-AST-005, personal Android devices. Supports MDM-D06 Section 4 and MDM-CTL-002. Threshold changes follow MDM-CTL-004.
Requirement	Corporate app access requires Android security patch level 2026-10-01 or later; devices below are blocked. Before enforcement, IT Operations confirms update availability by model and region, informs users and records the effective date. The threshold is reviewed monthly.
Verification	Access is blocked below the threshold and allowed at it, and is reassessed after updating. Meeting the patch level does not bypass other requirements.
Constraints and status	The threshold is project-defined and matches Section 3.4; the date does not advance automatically. App Protection checks the patch level but does not install updates, which depend on the manufacturer. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android app protection policy settings; data protection framework. Reviewed 30 October 2026.

4.10 BYOD Offline Access Limit

Requirement ID: MDM-STD-018

Field	Details
Scope and traceability	Corporate data in approved apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Section 4 and MDM-CTL-002.
Requirement	Corporate data access in protected apps is blocked after 24 hours (1,440 minutes) offline. Access returns only after the app reconnects and passes authentication and protection checks; network availability alone does not count.
Verification	Test access before and after expiry on both platforms, including app suspension and reopening, and confirm revalidation after reconnection.

Field	Details
Constraints and status	Timers differ by platform: Android starts when the app detects it is offline, iOS/iPadOS counts from each app's last Intune check-in. Blocking is not guaranteed at exactly 24 hours. This requirement blocks access only; data removal after a long offline period is in Section 4.14. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings. Reviewed 30 October 2026.

4.11 BYOD Failed PIN Attempts and Disabled Accounts

Requirement ID: MDM-STD-019

Field	Details
Scope and traceability	Corporate contexts in approved apps on MDM-AST-005 and MDM-AST-006. Supports MDM-D06 Sections 4 and 7; complements MDM-STD-014 and MDM-STD-018.
Requirement	After 5 failed PIN attempts, the app PIN is reset. The user must sign in with the corporate account, including MFA where required, and set a new PIN that meets Section 4.6. When the account is disabled, corporate access in protected apps is blocked.
Verification	Test 5 failed attempts, authenticated recovery, and rejection of a weak replacement PIN. Disable a test account and confirm blocking online and offline, recording any detection delay.
Constraints and status	Accounts are disabled through the authorized identity process; App Protection only reacts once it detects the change and does not end every session or offline access at once. These actions block access but do not remove data. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; data protection framework. Reviewed 30 October 2026.

4.12 BYOD Backup, Synchronization and Printing Restrictions

Requirement ID: MDM-STD-020

Field	Details
Scope and traceability	Corporate data in approved apps on MDM-AST-005 and MDM-AST-006. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Corporate app data is kept out of personal device backups (Android backup, iCloud and iTunes) and is not synchronized to native apps or add-ins. Printing corporate data from BYOD is blocked.
Verification	On both platforms, test backup and restore, native contact and calendar sync (including Outlook), add-ins and printing. Record blocked operations and unsupported cases.
Constraints and status	Enforcement depends on app support, and some apps may not honor the sync restriction. These controls do not remove data already exported or backed up. Unsupported paths must be resolved before design closure. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings; supported Intune apps. Reviewed 30 October 2026.

4.13 BYOD Notifications and Screen Capture Protection

Requirement ID: MDM-STD-021

Field	Details
Scope and traceability	Approved work apps on Android and iOS/iPadOS BYOD. Supports MDM-CTL-002 and MDM-D06 Section 5.
Requirement	Notifications from protected apps do not show corporate content; generic alerts are allowed. Screen capture of corporate content is blocked, including screenshots, recording, screen sharing and mirroring on iOS/iPadOS. Users accept these restrictions when joining BYOD.
Verification	Check notification content on the device and connected accessories. Test screenshots, recording, screen sharing and app-switcher previews, and record app versions and results.
Constraints and status	Support varies by app and version; on iOS/iPadOS, screen capture blocking needs a recent Intune SDK in each app.

Field	Details
	Unsupported behavior must be resolved before activation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings.

4.14 BYOD Extended Offline Data Removal

Requirement ID: MDM-STD-022

Field	Details
Scope and traceability	Approved work apps on Android and iOS/iPadOS BYOD. Supports MDM-D06 Sections 5 and 7; complements MDM-STD-018.
Requirement	After 90 days offline, the app requires reconnection and sign-in. If sign-in fails, the work account and its app data are removed selectively; personal data and the device are not wiped. The 24-hour access block in Section 4.10 still applies.
Verification	Test successful and failed reauthentication after the period, interaction with the 24-hour block, removal of corporate data and preservation of personal data, on each platform and tested app.
Constraints and status	Removal is not guaranteed at an exact time or across all apps at once, and elapsed time is not proof of removal. This does not replace offboarding or incident removal (Section 4.15). The 90-day trigger is project-defined. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings (conditional launch); NCA ECC 2:2024, 2-6-3-3 (supporting).

4.15 BYOD Selective Wipe Requests and Verification

Requirement ID: MDM-STD-023

Field	Details
Scope and traceability	Corporate data in protected apps on Android and iOS/iPadOS BYOD. Supports MDM-D06 Sections 5 and 7.
Requirement	Corporate app data is removed by selective wipe when

Field	Details
	offboarding, BYOD withdrawal or an incident requires it: per device for a lost or withdrawn device, per user for a departure. Personal data and full-device wipe are out of scope. IT Operations raises and tracks each request against the authorizing record, confirms the target by more than the device name, and revokes access without waiting for removal.
Verification	Each request keeps its status, target, timestamps and evidence. Pending or failed requests stay open with follow-up. Test device and user targeting, online and offline behavior, and preservation of personal data.
Constraints and status	Completion is not immediate. Submitting a request, or its disappearance from the report, is not proof of completion; evidence must be captured within the report's four-day retention. Copies exported earlier are not assumed removed. A user-level wipe continues until the user is taken off its list. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: How to wipe only corporate data from Intune-managed apps; NCA ECC 2:2024, 2-6-3-3.

4.16 BYOD App Version and Protection Compatibility

Requirement ID: MDM-STD-024

Field	Details
Scope and traceability	The six approved work apps on Android and iOS/iPadOS BYOD. Supports MDM-CTL-002 and MDM-D06 Sections 4 and 5, and Sections 4.1 to 4.15 of this standard. Changes follow MDM-CTL-004.
Requirement	Each approved app has a minimum version per platform that supports the required protections, plus a minimum SDK version on iOS/iPadOS. Older versions are blocked after a communicated update period. A baseline record lists each app, platform, minimum version, source and enforcement date, and is reviewed monthly.
Verification	Test access below and at each minimum, restoration after updating, and that one app's threshold is not applied to

Field	Details
	another.
Constraints and status	Exact version thresholds and enforcement dates are still to be set. Meeting the version does not prove that every protection works. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Android and iOS/iPadOS app protection policy settings (conditional launch).

4.17 BYOD Privacy Notice and Activation Record

Requirement ID: MDM-STD-025

Field	Details
Scope and traceability	Employees requesting Android or iOS/iPadOS BYOD access. Supports MDM-D06 Sections 4 and 6.
Requirement	Before activation, the employee acknowledges a version-controlled privacy notice. It states what the company can see, why, who can access it, the protection restrictions, how corporate data is removed and its limits, and a support contact. IT Operations activates BYOD only after acknowledgment, prior manager approval and technical checks; no check replaces another. The activation record keeps the employee, notice version, acknowledgment time, approval, check result and activation date, with access limited to business need.
Verification	Confirm on both platforms that what the company can actually see matches the notice, and that activation is refused when acknowledgment, approval or a technical check is missing.
Constraints and status	App protection reporting is not MDM device compliance, and documented fields are not verified tenant observations. The records repository, permissions and retention period are confirmed before operational use. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	MDM-D06 Sections 4 and 6; Microsoft Learn: How to monitor app protection policies.

5. Shared Security Requirements

5.1 Corporate Data Protection in Transit

Requirement ID: MDM-STD-026

Field	Details
Scope and traceability	Corporate and BYOD Android and iOS/iPadOS devices using approved Microsoft 365 services. Supports MDM-D06 Section 5 (encryption in transit).
Requirement	Corporate data is encrypted in transit: TLS 1.2 or later for connections, and SRTP for Teams audio and video. Approved apps validate server certificates, with no unencrypted fallback or validation bypass. IT Operations confirms supported clients and the network path, including any proxy or TLS inspection.
Verification	Keep service documentation and configuration evidence. Check representative connections on both platforms and management models for TLS version, certificate validation and Teams media protection, and record test limits.
Constraints and status	The Intune app encryption setting covers data at rest, not in transit. Microsoft documentation does not prove this environment's behavior. Transport encryption is not end-to-end, and does not cover email delivery to external recipients. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Encryption for data in transit; encryption for SharePoint, OneDrive, Teams and Exchange.

5.2 Intune Administrative Roles and Scope

Requirement ID: MDM-STD-027

Field	Details
Scope and traceability	Administrative and reviewer access to Microsoft Intune for the mobile service. Supports MDM-CTL-005 and MDM-D06 Section 3.
Requirement	Each person gets only the permissions and scope their tasks need. Operational administration, evidence review and role management are separate. Routine operational roles cannot grant or expand access. Wipe permissions are limited to designated IT Operations staff and an approved backup.

Field	Details
	Cancelling a pending selective wipe needs documented approval, with the request, reason, approver and operator recorded. Reviewers get scoped read-only access only when needed. Broad roles such as Global Administrator are avoided where narrower roles work. Each assignment records the role, tasks, scope, justification and approval.
Verification	Test permitted actions and attempts to change out-of-scope objects, change role assignments, or write through reviewer access, checking the combined effect of all assigned roles.
Constraints and status	Some permissions are bundled, so separation is partly procedural; for example, the permission to update apps also allows cancelling pending wipes. Exact roles and scopes are still to be defined. Approval and review are set in Section 5.4. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Role-based access control with Intune; RBAC and scope tags; custom roles (managed apps permissions).

5.3 Intune Administrative Authentication

Requirement ID: MDM-STD-028

Field	Details
Scope and traceability	Human accounts with administrative access to Intune, through Entra roles or Intune role assignments. Supports MDM-CTL-005; complements MDM-STD-027.
Requirement	Intune administrative access requires phishing-resistant MFA, with approved methods registered before enforcement. All administrative accounts are covered, including those assigned through Intune roles and not only the Entra Intune Administrator role. Recovery and emergency access are defined and tested with the IAM owner, and any exception is documented, authorized and monitored.
Verification	Approved methods succeed and weaker methods are rejected. Coverage of both kinds of administrator, the recovery arrangements and sign-in records are checked.

Field	Details
Constraints and status	Depends on the enterprise privileged-access control and its owner, and on licensing and method support. This requirement protects administration of the service; it does not allow administrative sessions from mobile devices. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Require phishing-resistant MFA for administrators; Conditional Access authentication strengths.

5.4 Intune Administrative Access Approval and Review

Requirement ID: MDM-STD-029

Field	Details
Scope and traceability	Administrative access to the mobile service through Entra roles and Intune role assignments. Supports MDM-CTL-005; complements MDM-STD-027 and MDM-STD-028.
Requirement	Access is approved before assignment and reviewed every quarter and whenever a role or employment status changes. The IT Operations Manager approves and reviews team members' access; the CISO approves and reviews the Manager's access. A separately authorized role administrator makes each assignment. Reviews cover direct and group-based access, combined permissions, scope and privileged Entra roles, and record a keep, adjust or remove decision per assignment. Leavers and role changes are actioned at once, not at the next review.
Verification	Sample grants for prior approval by the right approver and correct implementation. Confirm each review was complete, done by the assigned reviewer, and that removals were completed. Evidence kept: the access list reviewed, reviewer, date, decisions and completion proof.
Constraints and status	No one approves, implements or reviews their own access. The CISO holds no Intune administrative access. The GRC Analyst does not approve, review or change access; GRC tests whether approvals and reviews happened, using read-only evidence. Integration with the enterprise workflow is pending. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.

Field	Details
Source	Project-defined, based on MDM-CTL-005 and its framework mapping in MDM-D05.

5.5 Device Report Repository and Access Protection

Requirement ID: MDM-STD-030

Field	Details
Scope and traceability	Employee device management reports stored outside Intune, including manually prepared reports. Supports MDM-CTL-006 and MDM-D06 Section 6.
Requirement	Reports are kept in a restricted library on a dedicated corporate SharePoint site. Access follows business need, with three separate levels: readers view, preparers upload and update, and designated administrators manage access on approved requests. External sharing, "Anyone" links and organization-wide links are disabled. Permissions and membership are reviewed quarterly and when responsibilities change.
Verification	Readers and preparers can do only their permitted actions. Unauthorized access, permission changes and broad sharing links are refused. Review and correction evidence is kept.
Constraints and status	Read access does not stop downloading or copying, and repository permissions do not control copies after export. The site, groups and permission mapping are confirmed with the SharePoint owner before use. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft: manage sharing settings for SharePoint and OneDrive; access requests; sharing and collaboration options.

5.6 Device Compliance Report Accuracy

Requirement ID: MDM-STD-031

Field	Details
Scope and traceability	Manually compiled compliance reports for corporate devices enrolled in Intune. Supports MDM-CTL-008, MDM-RSK-008 and MDM-AST-009. Control owner: IT Operations Manager.

Field	Details
Requirement	Each device stays matched to its own compliance state from extraction to release. The Intune managed device ID is the matching key, never the device name, user email or Entra device ID. Each report shows the device ID, name, serial number and user where available, compliance state, last sync and extraction time. The source snapshot is kept. Before release, a second IT Operations team member checks every device ID and state against the snapshot and records the result. Discrepancies are investigated, corrected and rechecked; a corrected version goes to recipients of any affected report.
Verification	Test swapped device and status pairs, duplicate names and one user with several devices. Confirm detection, correction and independent review evidence.
Constraints and status	A reporting discrepancy is never recorded as device noncompliance, and a match is never guessed. Last sync and extraction time are different. An accurate report does not prove current compliance, and BYOD app protection status is not MDM compliance. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: managedDevice resource type, Microsoft Graph v1.0.

5.7 Contractor Authorization Register and Reminders

Requirement ID: MDM-STD-032

Field	Details
Scope and traceability	Contractors using company-issued mobile devices. Supports MDM-CTL-007 and MDM-D06 Section 7.
Requirement	A restricted register records each contractor's accounts, device IDs, sponsor, authorization end date and time with time zone, approval reference, reminders sent and change history. An automated daily check reminds the sponsor one calendar month before expiry, then every seven days. An extension needs recorded approval from the Responsible Business Manager before expiry; a pending request does not extend access. Sponsors report early departures at once. IT Operations monitors failed runs and escalates to the IT

Field	Details
	Operations Manager.
Verification	Test scheduling, time zones and month-end dates, extensions, early departures, late entries, failed runs and unauthorized changes to the register.
Constraints and status	Reminders do not enforce expiry: access ends at the authorized time whatever happens to the reminder (Section 5.8). A sent reminder does not prove it was read. The automation's licensing and ownership need validation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Power Automate triggers and licensing.

5.8 Contractor Access Revocation and Verification

Requirement ID: MDM-STD-033

Field	Details
Scope and traceability	Contractors on company-issued devices with individual cloud-only Entra ID accounts. Supports MDM-CTL-007 and MDM-D06 Section 7.
Requirement	Access is revoked at authorization expiry or at the early-departure time; only an extension approved before expiry changes the deadline. IT Operations prepares an offboarding task with the exact end time, an operator, a backup and out-of-hours cover; missing cover never extends access. At the deadline, authorized administrators disable the account, revoke sign-in sessions and remove app, group and shared-resource permissions.
Verification	Confirm that access is actually blocked, not only that the account shows as disabled. Keep the task reference, action results, timestamps and open issues. The IT Operations Manager monitors due tasks and escalates any missed or incomplete action at once, with an owner and target time. Test expiry, early departure, extension, operator absence, new sign-ins and existing sessions.
Constraints and status	Existing sessions may continue for a time depending on tokens and apps, so blocking delays are measured. Device recovery and data removal are tracked separately and never

Field	Details
	delay revocation. Closing the task is not proof of revocation. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Revoke user access in Microsoft Entra ID.

5.9 Corporate Device Recovery and Data Removal

Requirement ID: MDM-STD-034

Field	Details
Scope and traceability	Corporate Android (Fully Managed) and supervised iOS/iPadOS devices. Supports MDM-D06 Sections 5 and 7, and MDM-CTL-007 for contractor offboarding.
Requirement	Returned devices are recorded (device IDs, previous user, receipt date, receiver) and fully wiped before reassignment, after retention and incident-evidence checks. A reassigned device is re-enrolled and checked for protection and compliance before access is given. A lost or stolen device is wiped remotely once reported, without waiting for recovery; delaying the wipe to keep incident evidence needs CISO approval on record. Unreturned devices are escalated, and access revocation never waits for recovery.
Verification	Each wipe result is tracked. An unconfirmed wipe stays open with an owner and follow-up date. Returned devices are inspected for a clean reset before re-enrollment. Test wipe and re-enrollment on both platforms, including lost devices, offline devices and failed actions.
Constraints and status	Sending the command, deleting the record or a reported status is not proof of removal. Remote wipe depends on device connectivity. Full-device wipe is never used on BYOD. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Microsoft Learn: Wipe devices with Microsoft Intune; NCA ECC 2:2024, 2-6-3-3.

5.10 Approved Applications and Storage for Corporate Devices

Requirement ID: MDM-STD-035

Field	Details
Scope and traceability	Company-owned Android and iOS/iPadOS devices enrolled in Intune. Supports MDM-D06 Sections 4 and 5.
Requirement	The approved business apps are the same six as for BYOD: Microsoft Outlook, Teams, OneDrive, Word, Excel and PowerPoint, used with corporate accounts. Corporate data is stored only in the company's OneDrive for Business and authorized SharePoint locations. Enrollment, management and authentication components are allowed but do not extend the app list. Mobile browser access to corporate services stays prohibited.
Verification	On both platforms, confirm approved apps, corporate-account use and permitted storage. Test unapproved clients, personal accounts, unauthorized destinations and the sign-in flows the apps need.
Constraints and status	Installing approved apps does not by itself block other clients or limit storage to the company's tenant; data transfer restrictions and access design (MDM-D08) do that. Platform-specific enforcement is still to be mapped. Implementation and effectiveness are assessed in MDM-D09 and MDM-D10.
Source	Project-defined, based on MDM-D06 Sections 4 and 5.